

Lessons Learned & Root Cause Analysis

Why "Lessons Learned" Is the Most Important Phase

Every incident is expensive. The only thing that makes it worth anything is `the system getting stronger`. Skip this phase and you've paid the price for nothing.

The Retro Format

Post-Incident Review (PIR), run when the dust settles:

`Timeline` – what happened, when, who (facts only)

`What went well` – name the wins, reinforce them

`What went wrong` – detect gaps, slow calls, missing data

`Root cause analysis` – why did it happen *fundamentally*

`Action items` – owned, dated, tracked (SWIMLanes: Specific, With Owner, In time, Measurable)

`Metrics` – record MTTD, MTTR for every incident

Root Cause: 5 Whys (Toolbox Classic)

Example – "attacker got in via RDP":

Why? → RDP exposed to internet

Why? → firewall rule moved 'temporarily'

Why? → no change-management gating for firewall

Why? → process exists but no enforcement muscle

Why? → leadership didn't see firewall changes as risk

Management fixes cost more than technical ones – and they're the ones that stick.

The 5 Whys Pitfalls

Don't stop at "human error" – it's usually the last expression of a system problem ("user clicked link" → why was that click not blocked? → why no simulated-phish training? ...)

Blame-free zone – people stop reporting incidents if they fear punishment (M09's 'reward for reporting')

Beware gut-checks – root cause might be lower than the loudest complaint

Turning Findings Into Rules

Every PIR should yield DETECTION improvements:

New Sigma rule for the technique used

New log source enabled (the reason it was missed was *no telemetry*)

New playbook path for the scenario

Track "detection coverage gaps" found in incidents – that's your roadmap to better defense:

Incident	Technique	What we missed	Rule now
-----	-----	-----	-----
Phish	Delivery	user clicked	add DMARC-reject
Ransom	Defense evasion	no child-process rule	add Sigma
Exfil	Exfiltration	long-duration DNS	add beacon detector

Metrics the Org Actually Cares About

MTTD / MTTR (down or flat)

Escapements (incidents that should have been caught)

Recurring incidents (same root cause twice = red flag for the program)

% of PIR actions completed on time – the honesty meter

Final message: incidents are inevitable; repeat incidents are not. The gap between them is filled by the lessons-learned discipline you build today.

[← Containment Strategies & Rec...](#)

Module complete ✓